

PENETRATION TESTING & AUDIT REPORT

MONTH 1 FINAL SECURITY ASSESSMENT — COMPREHENSIVE AUDIT

Target: Auth Infrastructure & Network
Date: July 2026
Assessor ID: CX-INT-2026-CYB-0044

1. EXECUTIVE SUMMARY & ASSESSMENT OVERVIEW

During Month 1 of the CloudExify Cybersecurity Summer Internship 2026, an exhaustive grey-box security assessment, application penetration test, and cryptographic compliance audit were performed on the authentication infrastructure (secure_auth.py), web application frontend (app.py), symmetric encryption engine (encryption_examples.py), and associated local network protocols.

The primary target of this audit was to rigorously stress-test application mechanisms against industrial threat vectors including Brute-Force authentication attacks, Rainbow Table pre-computation leaks, cleartext transport credential sniffing, and key-management exposure risks. The assessment verified both software-layer defenses and network-layer vulnerabilities.

Target System	CloudExify Auth Portal	Overall Risk Rating	MEDIUM (MITIGATED)
Lead Assessor	Hammad UI Hassan	High Severity Findings	1 CRITICAL / HIGH
Internship ID	CX-INT-2026-CYB-0044	Passed Security Controls	3 VERIFIED

2. SCOPE & TARGET ASSET MATRIX

Component / Module	Target Endpoint / Asset	Assessment Focus & Testing Methodology
Authentication Core	secure_auth.py / users.json	Salted Bcrypt password hashing, complexity rule enforcement, account lockout policy mechanisms.
Web Application UI	app.py (Port 5000)	Form input sanitization, session handling, rate-limiting HTTP responses, flash message disclosures.
Cryptographic Engine	encryption_examples.py / secret.key	Fernet (AES-128-CBC) symmetric encryption key generation, persistence on disk, and integrity checks.
Network Reconnaissance	127.0.0.1 / Local LAN Interface	Nmap/Zenmap active port scanning, service version detection, and Wireshark HTTP packet sniffing.

3. COMPREHENSIVE VULNERABILITY ANALYSIS & AUDIT FINDINGS

FINDING 01: Unencrypted Cleartext Transmission over Plain HTTP [HIGH SEVERITY]

Detailed Observation: During passive network traffic analysis using Wireshark (documented in `wireshark_http_capture.png` and detailed in `wireshark_findings.txt`), user registration and authentication requests transmitted over the local network via HTTP POST/GET methods revealed cleartext parameter payloads.

Threat Scenario & Technical Impact: An adversary positioned on the same network segment (e.g., local LAN or unencrypted Wi-Fi) can leverage ARP Spoofing or passive packet sniffing to capture raw authentication strings, session cookies, and sensitive API parameters without needing decryption keys.

Remediation Strategy: Mandatory enforcement of TLS/SSL (HTTPS) across all web endpoints, binding Flask behind an Nginx reverse proxy, and enabling HTTP Strict Transport Security (HSTS) headers.

FINDING 02: Rate Limiting & Brute-Force Lockout Engine [PASSED]

Detailed Observation: The core authentication layer was subjected to simulated dictionary and credential stuffing attacks. The system successfully tracked consecutive authentication failures on specific accounts and enforced a hard account lockout state after exactly 3 invalid login attempts.

Threat Scenario & Technical Impact: Effectively mitigates automated brute-force attacks, dictionary attacks, and high-frequency password spraying attempts against user accounts.

FINDING 03: Cryptographic Storage & Salted Bcrypt Hashing [PASSED]

Detailed Observation: Audit of disk storage persistence (`users.json`) verified that plain-text passwords are never recorded to disk under any condition. User passwords are converted to salted hash digests using standard bcrypt key derivation with an optimal work factor.

Threat Scenario & Technical Impact: Protects account credentials against offline rainbow table attacks and database leak exposures even if local disk access is compromised.

4. NETWORK RECONNAISSANCE & SCANNING ANALYSIS

An active port scan was executed against the local target host using Nmap/Zenmap (`nmap -F 127.0.0.1`) to evaluate open entry points and service exposure.

Nmap Reconnaissance Execution Summary:

- **Host State:** Active / Online (127.0.0.1)
- **Active Service Discovered:** Port 5000/TCP (Flask Development HTTP Web Server)
- **Audit Status:** No unauthorized administrative services (e.g., Telnet, unauthenticated SSH, or legacy FTP daemons) were detected running on open host ports.

5. MITIGATION ROADMAP & STRATEGIC RECOMMENDATIONS

1. **Production HTTPS Deployment:** Bind the Flask application server to an Nginx or Apache reverse proxy equipped with Let's Encrypt SSL/TLS certificates.
2. **Secure Key Management:** Transition symmetric encryption keys (`secret.key`) from local disk files into environment variables or dedicated secret management stores.
3. **Session Security Flags:** Hardened HTTP response headers by enforcing `HttpOnly`, `Secure`, and `SameSite=Strict` attributes on all session cookies.

Assessor Signature: Hammad UI Hassan

Role: Cybersecurity Intern @ CloudExify

Internship ID: CX-INT-2026-CYB-0044

Report Status: **APPROVED & VALIDATED**

Date: July 29, 2026